

Mise en place d'une DMZ sécurisée

Pare-feu pfSense et WAF ModSecurity

Travaux pratiques · BTS SIO – option SISR

Objectif

Concevoir et mettre en œuvre l'architecture d'un réseau d'entreprise segmenté en trois zones. Le réseau interne (LAN) devait rester totalement isolé de l'extérieur, tout en exposant sur Internet un serveur web hébergé dans une zone démilitarisée (DMZ). Objectif de sécurité : un utilisateur extérieur peut atteindre le serveur web, mais jamais le réseau interne.

Architecture mise en place

Un pare-feu pfSense doté de trois interfaces (LAN, DMZ, WAN) assure le routage et le filtrage entre les zones. Le LAN héberge une machine cliente Ubuntu qui reçoit son adresse via le serveur DHCP de pfSense. La DMZ héberge un serveur web Apache sous Ubuntu, protégé par un pare-feu applicatif. Les trois zones sont placées sur des sous-réseaux distincts.

- LAN : machine cliente Ubuntu (adressage automatique par DHCP).
- DMZ : serveur web Apache (adressage fixe).
- WAN : accès Internet, simulant les utilisateurs extérieurs.

Politique de filtrage (défense en profondeur)

Les règles du pare-feu ont été définies pour appliquer le principe du moindre privilège entre les zones :

- LAN vers WAN : autorisé (accès Internet du poste client).
- LAN vers DMZ : autorisé (accès au serveur web interne).
- WAN vers DMZ : autorisé uniquement sur les ports web (HTTP/HTTPS).
- DMZ vers WAN : autorisé (mises à jour du serveur).
- DMZ vers LAN : bloqué — le serveur exposé ne peut pas atteindre le réseau interne.
- WAN vers LAN : bloqué — l'extérieur ne peut jamais joindre le LAN.

Sécurisation applicative du serveur web

Le serveur Apache a été protégé par le pare-feu applicatif ModSecurity (WAF), couplé aux règles OWASP Core Rule Set. La protection a été validée par des tests d'attaque réels lancés depuis le poste client : une tentative d'injection SQL et une tentative de XSS ont toutes deux été bloquées par le WAF, ce que j'ai confirmé dans les journaux de ModSecurity.

Compétences mobilisées

- Concevoir une solution d'infrastructure réseau (bloc 2 SISR).
- Installer, tester et déployer une solution d'infrastructure réseau (bloc 2 SISR).
- Assurer la cybersécurité d'une infrastructure réseau, d'un système, d'un service (bloc 3).
- Segmentation réseau, filtrage et principe de défense en profondeur.
- Mise en œuvre et test d'un pare-feu applicatif (WAF) face à des attaques web courantes.